AUDIT REPORT

Internal Security Audit Report: NovaBrew Supply Co.
Date: April 21, 2026
Auditor: Ícaro de Souza Mariano

Executive Summary - This report documents an internal security audit conducted for NovaBrew Supply Co. Following the recent launch of their direct-to-consumer e-commerce platform, this audit aims to assess the current security posture, identify vulnerabilities within the network architecture, and evaluate compliance with data protection standards (PCI DSS and GDPR).

Key Findings & Control Assessment - The rapid expansion of the e-commerce platform has introduced significant security gaps, particularly regarding network visibility and access controls.

CATEGORY	STATUS	FINDING
Network Monitoring	Vulnerable	No SIEM or centralized log management is implemented. The environment lacks visibility into potential brute-force attacks or anomalous activities on the e-commerce portal.
Access Control	Non-Compliant	Warehouse staff and corporate office employees share the same network segment. Role-Based Access Control (RBAC) is not strictly enforced across departments.
Data Protection	Critical	Customer payment data is processed securely via a third-party gateway, but the API keys used for this integration are currently hardcoded in plain text within the application's source code.

Compliance Gaps

- **PCI DSS:** Hardcoded API keys expose the payment gateway integration to severe risks, violating secure coding and data protection requirements.
- **GDPR:** The lack of centralized logging makes it difficult to detect breaches promptly, which could hinder the company's ability to notify affected users within the mandatory 72-hour window.

Recommendations & Action Plan - To secure the new e-commerce infrastructure and ensure compliance, the following actions are recommended for immediate implementation:

1. **Secure Secrets Management:** Remove all hardcoded API keys from the source code and implement a secure secrets management tool (e.g., HashiCorp Vault or AWS Secrets Manager).
2. **Deploy SIEM & Logging:** Implement a centralized logging solution to provide the SOC team with real-time visibility into network traffic and application events.
3. **Network Segmentation:** Segment the network to isolate the warehouse IoT devices from the corporate environment and the customer-facing e-commerce servers.
4. **Implement RBAC:** Enforce the Principle of Least Privilege by implementing strict Role-Based Access Control for all employees.